

钱包方案设计思路

一、我们不能做私钥托管服务的原因

1. 由于以太坊系私钥的使用权等于数字资产的所有权，因此提供私钥托管服务等价于资产托管服务；
2. 资产托管服务必须要资产托管牌照才能提供服务，否则不合法；
3. 绿联银行有资产托管牌照，但是 DTT 稳定币这类的资产由于某种原因（各种工作量）不能用绿联的资产托管牌照；
4. 有资产托管牌照的第三方私钥托管服务费用昂贵，现阶段不考虑；

二、目前平台钱包方案可以不算作私钥托管的解释

1. 平台不实际保存私钥明文，只保存私钥密文；同时用户有该密文管理权：导入、导出、删除（律所认为 3 个必须都要有）；
2. 签署用户协议与声明：平台不提供私钥托管服务，只提供钱包连接工具，可以用于方便用户使用自己的私钥进行交易签名；
3. 平台在任意时间，都不会保存或使用临时解密的私钥；
4. 律所认可上述说法；
(这也带来了一个系统设计上的限制：一个企业所有上链操作必须由用户输入交易密码完成，不可由系统提供自动签名等方式完成)

三、无法证明没有通过技术手段在不告知用户情况下盗用用户私钥，我方的风险规避方式

1. 事先与 MAS 和律所达成一致，我方实现方案完全合规；

四、私钥导出后仍然支持导入使用，可能会出现用户保管不善导致资产损失，与我方进行纠纷，我方的风险规避方式

1. 签署用户协议与声明：平台只提供钱包连接工具，资产的损失与我方无关；

五、需要增加 MPC 钱包的原因

1. 需要通过企业审计（MAS 不关心）：基于【二】的原因用户必须要有导出功能，但由于以太坊系私钥的使用权等于数字资产的所有权，有的企业不允许企业内任意一个用户拥有完整私钥；
2. MPC 技术可以允许将完整私钥通过分片的方式分发给不同的用户，使用时可以不形成完整私钥；

3. 上述 1 也是 MPC 钱包的导出功能不直接导出完整私钥而是导出分片的原因；

六、平台推出 Multi Signer 钱包的原因

1. 要满足【五】使用 MPC 钱包，而 MPC 钱包的分片也必须由不同用户持有，因此上链操作也必须改为多签形式，也就变成了多签钱包
2. 这也是为什么多签钱包只能使用 MPC 钱包来实现，不能采用智能合约钱包的方案

七、为什么 Single Signer 钱包可以不使用 MPC 方案

1. Single Signer 钱包是能满足【二】的规则
2. Multi Signer 钱包已经能提供 MPC 技术来解决【五】中提到的问题，Single Signer 使用 MPC 方案虽然能提升安全性，但优先级不高

八、不使用智能合约钱包方案的原因

1. 基于【二】中的第【1】点所提到的先决条件 - 企业用户应具备对其私钥的：导入、导出、删除这三项的必要功能
2. 隐私保护：相比 MPC 钱包的链下聚签，智能合约钱包在链上验证会暴露用户的多签逻辑
3. 可解释性：MPC 方案可更好得对外解释安全性的问题
4. 费用考虑：相较于 MPC 直接产生的一个以太坊签名，合约钱包涉及合约内验证签名/权限的逻辑，并且涉及链上管理 signer 的功能，将衍生较高更多的费用
5. 在进行企业级别的 private key 导出时候，存在企业级别的钱包地址的更替 (28/May 2024 updated by @罗世琦: 基于 user portal 分为 single signer 和 multiple signer，因此在资产和私钥的管理会区分为个人和企业级别的。企业级别的钱包地址在初始化创建后是不变的) -
6. 开发/功能的投入：完整的智能合约钱包的门户，当涉及到多签的要求时，需要签名的 signer 无被动通知的功能
7. 合规问题: 法律对智能合约钱包模糊，存在被定义不合规的风险

MPC 详细方案分析

基于满足企业级别用户的需求，可采用的 MPC 方案

1. 自研

描述：

MPC 技术是整个钱包架构中最底层的一环，同时钱包的安全架构是一个系统性工作，涵盖 TEE 集成、上层工程代码实现，如区块链全节点维护、交易提交上链序列化、节点解析、全链路监控和运维安全等方面。

pro:

- 可贴合 DTT 所需要实现的业务要求进行功能定制化，特性可以灵活调整
- 对自研系统拥有完全控制权
- 无采购费用，长期成本较低

con:

- 开发和维护 MPC 钱包存在较高的技术要求，存在完成交付的风险
- 从 0 到 1 的搭建所需的人力投入和耗时会很大，最大程度的开发时间和资源的投入
- 存在影响其余业务功能的迭代排期
- **预计人力投入为:**

【自研 MPC 门限钱包方案】（共计 64 人天）:

底层签名服务门限签名算法实现：（25 人天）

- 新私钥分片生成
- 分片重新生成
- 分片签名
- 分片签名聚合
- 算法调研与选型

钱包多签扩展：（前后端 34 人天）

- 多签钱包创建、导入、签名、分片密码修改、分片刷新
- 上链组件多签流程兼容 + 调用权限改造
- 企业钱包分片使用权限管理
- 钱包页面增加分片相关展示
- 相关功能通知

测试：（5 人天）

附:

【自研 智能合约 门限钱包方案】（共计 54 人天）:

钱包多签扩展：（前后端 34 人天）

- 企业钱包与用户钱包的功能划分设计与实现
- 上链组件多签流程兼容 + 调用权限改造
- 用户钱包上链权限管理
- 相关功能通知
- 相关功能通知

智能合约钱包的合约研发：（15 人天）

- 多签权限管理
- 企业私钥生成（待讨论）

测试：（5 人天）

【自研 MPC 门限钱包方案】	【自研 智能合约 门限钱包方案】
-----------------	------------------

只提供简单的门限逻辑	灵活性高、可编程自定义复杂签名逻辑
变动时需参与方同时替换所有分片	可单独替换或修改参与签名的私钥
使用针对需求的自研 MPC 方案，若要替换第三方钱包需要进行改造	使用非 MPC 钱包方案，直接兼容第三方钱包
签名过程不上链，不公开签名规则	签名规则需上链，多签过程将被公开
资产在 EOA 地址中，可以直接用企业私钥进行控制	资产在合约钱包地址中，需要通过智能合约对资产进行控制
链下完成多次签名，无额外的 Gas 费用	链上增加多签验证逻辑，增加了交易 Gas 费用

2. 采购本地 MPC 节点 SDK 服务

描述：

供应商会根据其不同的 MPC 算法的支持程度，提供不同订阅价格的 MPC 节点 SDK 解决方案。该方案只是一个基础的 MPC 私钥管理及签名工具，即是一个底层的框架，上层的应用层需要我们自己定制化搭建，从而满足企业级别用户的需求。

pro:

- 利用厂商所提供的 MPC 堆栈，减少底层架构的开发时间和复杂度
- 基于底层的算法支持，协议支持以及终端支持，可基于此完成后续顶层应用程序客制化开发

con:

- 生成订阅费用-USD8k/month,
- 一定程度的开发时间的投入
- 对其余业务功能的迭代排期存在较小的影响
- **预计人力投入为:**

【集成 3rd MPC 门限钱包方案】（共计 45 人天）：

底层签名功能集成：（10 人天）

钱包多签扩展：同自研方案（30 人天）

测试：（5 人天）

3. 采购 MPC SaaS 服务

描述：

供应商提供完整的 MPC SaaS 服务

pro:

- 快速部署，缩短开发周期
- 提供全套服务（包括 Server 端和客户端应用）
-

con:

- 现成的 SaaS 服务所提供的顶层的应用存在和 DTT 解决企业级别用户的需求实现上有一定出入(代@罗世琦与 vendor 进行讨论是否可以完成需求的匹配) -> (20/May 2024 updated by @罗世琦: 和 vendor 确认之后，封装好的顶层服务无法兼容 DTT 的实际业务需求)
 - 初期订阅费为 **USD1350/month**，与资产量挂钩，长期成本很高
-